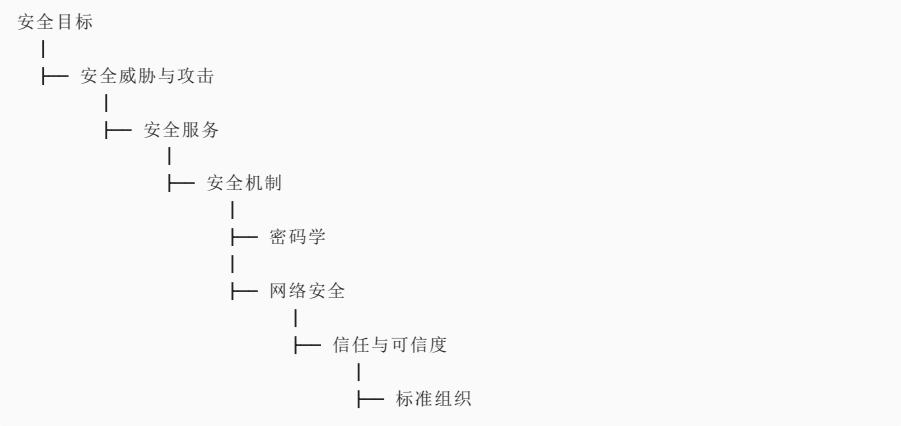
第 1 章 信息与网络安全概念

0. 学习目标总览

教材给出本章六个学习目标：

1. 描述保密性、完整性和可用性的关键安全需求。
2. 讨论必须应对的安全威胁和攻击类型，举例说明适用于不同计算机和网络资产的威胁与攻击类型。
3. 概述无密钥、单密钥和双密钥加密算法。
4. 概述网络安全的主要领域。
5. 描述信息安全的信任模型。
6. 列出和简要描述与密码标准相关的组织。

本章主线可以概括为：



教材开篇说明：本书着重于两个广泛领域，即**密码学**和**网络安全**。本章先介绍信息安全和网络安全的基本原理，包括安全攻击、安全服务和安全机制；再介绍密码和网络安全两个领域；最后讨论信任与可信度。

1. 学习目标 1：保密性、完整性和可用性的关键安全需求

1.1 三个基础概念

概念	教材核心含义	复习定位
网络空间安全	保护计算机、其他数字设备、网络设备和传输线路中存储、传输、处理的信息；保护包括保密性、完整性、可用性、真实性、可审计性；保护方法包括组织策略、程序和技术手段	最大范围，覆盖信息与网络
信息安全	保留信息的保密性、完整性和可用性，另涉及真实性、可审计性、不可否认性和可靠性	重点在信息本身，也包括纸质等物理信息

概念	教材核心含义	复习定位
网络安全	保护网络及其服务免遭未经授权的修改、破坏或泄露，并保证网络正确执行关键功能且没有有害作用	重点在网络及其服务

教材脚注采用 RFC 4949 的区分：信息是事实和想法，可用数据表示；数据是用特定物理方式表示的信息。安全文献通常不严格区分二者，本书也不作区分。

1.2 CIA 三元组

网络空间安全定义引出三个核心目标：**保密性、完整性、可用性**。这三个概念构成 CIA 三元组，体现数据、信息和计算服务的基本安全目标。

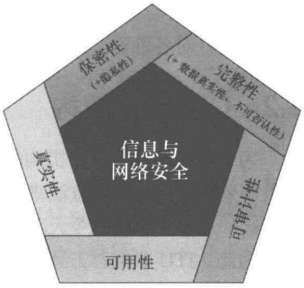


图 1.1　信息与网络安全的基本目标

图 1.1 信息与网络安全的基本目标

安全目标	教材展开	FIPS 199 角度的缺失
保密性 Confidentiality	包含数据保密性和隐私性	信息的非授权泄露
完整性 Integrity	包含数据完整性和系统完整性；数据完整性还包括数据真实性和不可否认性	信息的非授权修改和毁坏
可用性 Availability	系统能够及时运行，对授权用户不能拒绝服务	对信息和信息系统访问与使用的中断

1.2.1 保密性

保密性包含两个相关概念：

- **数据保密性**：确保隐私或秘密信息不向非授权者泄露，也不被非授权者使用。
- **隐私性**：确保个人能够控制或确定与自身相关的哪些信息可以被收集、保存，可以由谁公开以及向谁公开。

复习时注意：数据保密性强调“秘密信息不泄露、不被非授权使用”；隐私性强调“个人对自身相关信息的控制”。

1.2.2 完整性

完整性包含两个相关概念：

- **数据完整性**：确保信息和程序只能以特定和授权的方式改变。这里的信息包括存储的信息和传输的数据包。
- **系统完整性**：确保系统以正常方式执行预定功能，免于有意或无意的非授权操作。

数据完整性还包括两个重要内涵：

- **数据真实性**：一个数据对象确实是它所声称或被声称的对象。
- **不可否认性**：保证向信息发送方提供交付证明，并向接收方提供发送方身份的证明，使发送方和接收方以后都不能否认其已处理该信息。

1.2.3 可用性

可用性强调系统能够**及时运行**，并且对授权用户**不能拒绝服务**。在本章后文中，拒绝服务攻击正是针对可用性的典型攻击。

1.3 CIA 之外的两个常见目标

教材指出，在某些安全领域，还需要额外概念呈现完整的安全定义，其中常被提及的是**真实性**和**可审计性**。

补充目标	教材核心含义	关联作用
真实性 Authenticity	实体是真实、可验证、可被信任的；对传输信息来说，信息和信息源是正确的	验证用户是否为其声称身份，验证输入是否来自可信信源
可审计性 Accountability	实体行为可以唯一追溯到该实体	支持不可否认性、阻止、故障隔离、入侵检测和预防、事后恢复、法律诉讼

教材特别说明：真正安全的系统仍然不可实现，因此必须能够追查对安全漏洞负有责任的一方。系统必须保留活动记录，以便以后进行取证分析、追踪安全漏洞或解决争执。

1.4 信息安全的十项挑战

教材在 1.1.2 中列出信息和网络安全“既有趣又复杂”的原因，可作为理解 CIA 落地困难的背景。

1. 安全要求看似直观，但满足这些要求的机制非常复杂，需要缜密推理。
2. 设计安全机制或算法时，必须考虑各种潜在攻击；攻击者常以完全不同方式看问题。
3. 提供特定安全服务的方法并不直观，只有充分考虑威胁各方面，精心设计的机制才有意义。
4. 需要确定安全机制部署的物理位置和逻辑位置，例如网络中的位置、TCP/IP 协议层中的位置。
5. 算法和协议往往需要秘密信息，如加密密钥，由此带来密钥生成、分发、保护等问题；协议延迟也可能影响有时间限制的安全机制。
6. 计算机和网络安全本质上是入侵者与设计者或管理员之间的智力战争：入侵者只需找到一个弱点，设计者必须根除所有弱点。
7. 多数用户和系统管理员常在安全事件发生后才意识到安全投资收益。
8. 安全需要经常甚至连续监管，而短期、超负荷环境中难以做到。
9. 安全常作为事后措施加入系统，而非从系统设计一开始就纳入。
10. 许多用户甚至安全管理员认为强安全不利于系统高效工作、用户友好操作或信息使用。

2. 学习目标 2：安全威胁和攻击类型

2.1 OSI 安全架构中的三类关键概念

教材以 ITU-T X.800 的 OSI 安全架构作为系统化定义安全要求的方法。它主要关注安全攻击、安全机制和安全服务。



图 1.2　安全的关键概念

图 1.2 安全的关键概念

概念	教材定义	复习提示
安全攻击	任何危及信息系统安全的行为	已经表现为行为
安全机制	用来检测、阻止攻击或从攻击状态恢复到正常状态的过程，或实现该过程的设备	如何防护和恢复
安全服务	加强数据处理系统和信息传输安全性的处理过程或通信服务，目的是利用一种或多种安全机制阻止攻击	面向安全需求的功能
威胁	具有破坏安全潜在可能的情况或事件，可通过非授权访问、毁坏、泄露、消息篡改、拒绝服务等产生不利影响	潜在可能
攻击	试图收集、破坏、拒绝、降级或破坏信息系统资源或信息本身的恶意活动	恶意活动

2.2 被动攻击

X.800 和 RFC 4949 将攻击划分为**被动攻击**和**主动攻击**。

被动攻击试图获取或利用系统信息，但不影响系统资源。其特性是对传输进行窃听和监测，目标是获得传输的信息。

类型	教材说明	典型信息
信息内容泄露	电话、电子邮件消息、传输文件都可能含敏感或秘密信息，需要阻止攻击者获取传输内容	内容本身
流量分析	即使消息内容被加密，攻击者仍可观察通信主机身份和位置、消息频率和长度，并据此判断通信性质	模式、频率、长度、位置

被动攻击不涉及数据更改，因此很难被觉察。教材给出的防护重点是：通常用加密方法阻止这类攻击，重点是**预防而非检测**。

2.3 主动攻击

主动攻击试图改变系统资源或影响系统运行，包括对数据流进行篡改或伪造数据流。教材分为四类。

类型	教材定义	教材例子或说明
伪装	某个实体假装成其他实体	中间人攻击中，攻击者将服务器伪装成客户端、将客户端伪装成服务器；也可伪装成授权用户访问服务器资源
重放	攻击者未经授权将截获的信息再次发送	捕获客户端消息，然后把客户端消息重放到服务器
消息篡改	未经授权修改合法消息的一部分，或延迟消息传输，或改变消息顺序	将 “Allow John Smith to read confidential file accounts” 改为 “Allow Fred Brown to read confidential file accounts”
拒绝服务	阻止或禁止对通信设施的正常使用或管理	用大量数据淹没服务器；在服务器上触发消耗大量计算资源的动作；破坏整个网络、使网络失效或过载

主动攻击与被动攻击的防护重点不同：主动攻击难以绝对预防，因为这需要始终对所有通信设施和路径实施物理保护。因此重点在于**检测**并从破坏或延迟中**恢复**。检测本身具有威慑作用，也有助于预防主动攻击。

2.4 教材场景中的资产与安全影响

学习目标要求能举例说明不同计算机和网络资产面临的威胁与攻击。教材正文和习题给出了一组可用于复习的资产场景。

教材场景	可关联的安全目标	可关联的威胁或攻击
ATM 系统：用户通过 PIN 和银行卡访问账户	保密性、完整性、可用性、认证	PIN 泄露、账户数据被修改、服务不可用、身份冒充
电话交换系统：根据呼叫号码路由呼叫	可用性、完整性、保密性	路由或交换功能被干扰，呼叫数据被修改，通信内容或模式被观察
管理公开信息的网络服务器	可用性、完整性	DoS 影响公众访问，网页或公开信息被非授权修改
执法机构管理极端敏感调查信息	保密性、完整性、可用性	调查信息泄露、证据或记录被篡改、系统访问受阻
金融机构管理例行行政信息	完整性、可用性、保密性	行政数据被不恰当修改，系统不可访问；非隐私信息的保密性要求相对场景而定

教材场景	可关联的安全目标	可关联的威胁或攻击
合同签订机构的大单订购信息系统	保密性、完整性、可用性	预投标阶段合同信息泄露，订购信息被篡改，系统不可用
发电厂 SCADA 系统为军事设施供电	可用性、完整性、保密性	实时传感器数据被篡改，系统失效或过载，例行行政信息泄露

> **使用说明**
>
> 上表是把教材习题 1.1-1.4 的资产场景与本章安全目标、攻击类型对应起来，便于完成学习目标 2。具体影响等级需要结合题目要求另行判断。

3. 补充主线：安全服务与安全机制

虽然六条学习目标没有单独列出“安全服务”和“安全机制”，但教材开篇明确说本章要介绍这些基本原理，且 1.2-1.5 是理解攻击、密码学和网络安全的桥梁。

3.1 安全服务

安全服务是支持一个或多个安全需求的功能，支持的需求包括保密性、完整性、可用性、真实性和可审计性。安全服务通过安全机制来实现安全策略。

安全服务	教材核心含义
认证	保证通信真实性；单条消息场景中保证消息确实来自声称的发送方；连接场景中保证通信双方实体可信且连接不受第三方伪装干扰
对等实体认证	为连接中的对等实体提供身份确认，用于连接建立或数据传输阶段；希望保证实体未伪装或未对以前连接进行非授权重放
数据源认证	为数据来源提供确认，但不保护数据复制或修改；支持电子邮件等通信前未预先交互的应用
访问控制	限制和控制通过通信连接对主机与应用进行访问的能力
数据保密性	防止传输数据遭到被动攻击，可保护整段连接、单条消息或消息中特定范围，也包括防止流量分析
数据完整性	可应用于消息流、单条消息或消息指定部分；面向连接的完整性服务防止复制、插入、修改、重新排序、重放和数据破坏
不可否认性	防止发送方或接收方否认传输或接收过某条消息
可用性服务	确保系统可用，处理拒绝服务攻击导致的安全问题，依赖系统资源的恰当管理和控制

3.2 安全机制

教材在 1.5 中先概述安全机制，后续章节再详细讨论。

安全机制	教材核心含义
密码算法	可区分可逆密码机制和不可逆密码机制；可逆加密机制用于加密和解密；不可逆机制包括哈希算法和消息认证码

安全机制	教材核心含义
数据完整性	用于确保数据单元或数据单元流完整性的机制
数字签名	附加到数据单元或对数据单元进行密码转换的数据，使接收方证明数据来源和完整性，防止伪造
认证交换	通过信息交换确认实体身份的机制
流量填充	在数据流空隙中插入若干位，用于阻止流量分析
路由控制	为某些数据选择特定物理或逻辑安全路由，并允许在怀疑安全性受到破坏时更改路由
公证	使用可信第三方确保数据交换的某些属性
访问控制	执行资源访问权限的各种机制

4. 学习目标 3：无密钥、单密钥和双密钥加密算法

教材将密码学定义为数学的一个分支，涉及数据的变换。密码学是安全存储、数据传输以及各方之间安全交互的重要组成部分。

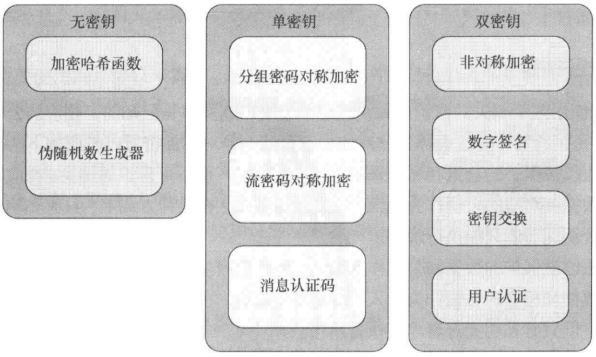


图 1.4　加密算法

图 1.4 加密算法

4.1 三类加密算法总览

类型	教材定义	关键词
无密钥	密码转换中不使用任何密钥	确定性函数
单密钥	转换结果是输入数据和单个密钥的函数；该密钥称为秘密密钥	对称加密
双密钥	不同计算阶段使用两个不同但相关的密钥，分别称为私钥和公钥	非对称加密

4.2 无密钥算法

无密钥算法是确定性函数，并具有某些对密码有用的特性。

类型	教材说明	作用
加密哈希函数	将变长文本转换为小的定长值，即哈希值、哈希码或摘要；具有额外属性，可用作其他加密算法的一部分	用于消息认证码或数字签名等
伪随机数生成器	产生确定性的、看起来像真正随机序列的数字序列或位序列；序列会在一定长度后重复	对某些密码学目的已足够

4.3 单密钥算法

单密钥算法依赖一个密钥。该密钥可能只有一个用户知晓，也可能由通信双方共享，用于保护彼此通信；在特定应用中，也可能由两方以上用户共享。

使用单一密钥的加密算法称为**对称加密算法**。加密算法以要保护的数据和密钥作为输入，产生难以理解的转换；解密算法以转换后的数据和同一密钥作为输入，恢复原始数据。

类型	教材说明
分组密码	按一系列分组处理数据；典型分组大小为 128 位；多数分组密码的操作模式使转换不仅取决于当前数据分组和密钥，也取决于先前分组内容
流密码	以位序列形式对数据进行操作，典型方式是使用异或运算逐位转换；转换依赖密钥
消息认证码 MAC	与数据分组或消息关联的数据单元；使用密钥的加密转换生成，通常是消息的加密哈希函数；拥有密钥的人可验证消息完整性

MAC 的验证逻辑：接收方对消息执行同样计算；若算出的 MAC 与消息附带的 MAC 匹配，则可确保消息未被篡改。

4.4 双密钥算法

双密钥算法使用两个相关密钥：**私钥**只对单个用户或实体已知，**公钥**对许多用户公开。使用双密钥的加密算法称为**非对称加密算法**。

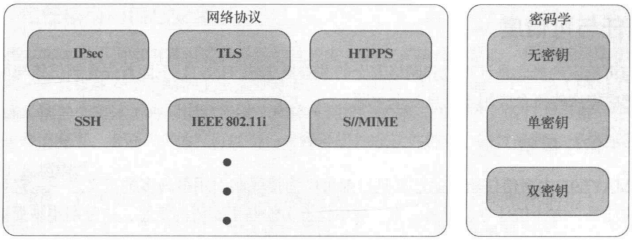
使用方式	输入与输出	复习含义
私钥加密，公钥解密	加密算法输入数据和私钥；解密算法输入转换后数据和对应公钥	只有私钥拥有者能执行加密，公钥拥有者能解密
公钥加密，私钥解密	加密算法输入数据和公钥；解密算法输入转换后数据和对应私钥	任何公钥拥有者可加密，只有私钥拥有者可解密

非对称加密的重要应用：

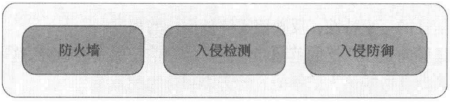
- **数字签名算法**：签名者通常使用私钥生成签名，拥有相应公钥的人可验证签名有效性，从而验证数据来源与完整性。
- **密钥交换**：在两方或多方之间安全分发一个对称密钥。
- **用户认证**：认证访问应用程序或服务的用户身份，也可认证应用程序或服务的真实性。

5. 学习目标 4：网络安全的主要领域

教材指出，网络安全涵盖三类对象：网络通信路径的安全、网络设备的安全、连接到网络的设备的安全。



(a) 通信安全



(a) 设备安全

图 1.5　网络安全的关键要素

图 1.5 网络安全的关键要素

5.1 通信安全

通信安全涉及对网络通信的保护，包括针对被动攻击和主动攻击的防护措施。

教材对网络协议的说明：

- 网络协议由控制网络中各点之间数据传输和接收的格式与过程组成。
- 协议定义数据单元（如数据包）的结构，以及管理数据传输的控制命令。
- 安全协议可以是现有协议的一部分或独立协议。

安全协议类型	教材例子
作为现有协议的一部分增强	IPsec 是 Internet 协议 IP 的一部分；IEEE 802.11i 是 IEEE 802.11 Wi-Fi 标准的一部分
独立协议	传输层安全性 TLS；安全外壳 SSH

所有这些协议的共同特征：使用许多加密算法作为提供安全性机制的一部分。

5.2 设备安全

设备安全保护网络设备和连接到网络的终端系统。教材给出的对象包括路由器、交换机、客户端和服务器。

主要安全问题：

- 入侵者访问系统并执行未经授权的操作；
- 植入恶意软件；
- 耗尽系统资源以降低系统可用性。

三类主要设备安全：

类型	教材核心含义
防火墙	硬件和/或软件功能，根据特定安全策略限制网络与连接设备之间的访问；充当过滤器，基于流量内容和/或流量模式规则允许或拒绝数据流量
入侵检测	硬件或软件产品，收集和分析计算机或网络中各区域信息，查找试图未经授权访问系统资源的尝试，并提供实时或接近实时警告
入侵防御	硬件或软件产品，检测入侵活动并尝试停止该活动，最好在入侵活动到达攻击目标前阻止

教材说明：这些设备安全功能与计算机安全领域关系更紧密。因此第六部分相比通信安全，对设备安全讨论更概略。

6. 学习目标 5：信息安全的信任模型

教材将信任与可信度称为计算机和网络安全的关键概念。它先介绍通用信任模型，再将这些概念应用到信息安全。

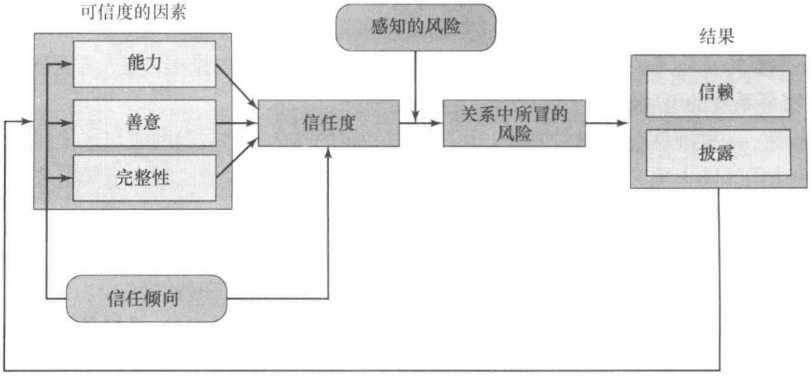


图 1.6　信任模型

图 1.6 信任模型

6.1 信任模型的基本概念

概念	教材核心含义
信任	信任方对被信任方的基于期望的意愿，这种期望易受被信任方行为影响；不管是否被监视或控制，被信任方都会执行对信任方重要的特定操作
可信度	实体信任的一个特性，反映实体被信任的程度
信任倾向	在广泛范围和信任目标中信任他人的趋势；影响个人依赖他人言语和行为的意愿
风险	衡量实体受到潜在情况或事件威胁的程度；通常由不利影响和发生可能性两个参数表示

图 1.6 表示的关系：**信任是信任方的信任倾向和被信任方的可信度的函数**。信任倾向也可表示为实体准备承受的风险级别。

6.2 建立可信度的三个因素

因素	教材说明
能力 Ability	也称技能 Competence，与被评估实体执行给定任务或被委托给定信息的潜能有关
善意 Benevolence	被信任方对信任方的善意处置意向，即值得信赖的一方无意对信赖方造成损害
完整性 Integrity	信任方对被信任方遵守其认为可以接受的一组原则的看法；完整性意味着采取必要措施以确保不会对信任方造成损害

根据信任级别和感知到的风险，信任方可以决定采取某种程度的冒险措施。冒险结果可能依赖于被信任方执行的操作，或依赖于向信任方披露的信息，且该信息会受到双方约定的保护。

6.3 信任模型和信息安全

教材对信息安全语境中的信任作出限定：信任是对实体以不损害由其组成系统的用户安全的方式执行的信心。信任始终限于特定功能或行为方式，并且仅在安全策略上下文中才有意义。

“实体”可以是：

- 硬件组件；
- 软件模块；
- 通过品牌和型号标识的设备；
- 站点或位置；
- 组织。

6.3.1 个人的可信度

组织中的个人包括内部用户和外部用户：

- 内部用户：雇员、现场承包商。
- 外部用户：客户、供应商。

对于内部用户，组织需要根据两方面政策为其授权信任层级：

政策	教材说明
人力资源安全	信息安全要求嵌入员工雇用期每个阶段，说明入职、日常管理和离职期间的安全相关动作；还要明确信息拥有者和保护信息的责任
安全意识和培训	向 IT 员工、IT 安全员工、管理员、IT 用户和其他雇员传播安全信息；较高安全意识和适当安全培训非常重要

对于外部用户，信任取决于环境。教材强调：信任是双向的。组织要确定对外部用户的信任层级，外部用户也关心其对所用信息资源的信任度。这种互信涉及公钥基础设施和用户身份认证协议。

6.3.2 组织的可信度

大多数组织依赖信息系统服务、外部组织提供的信息及合作伙伴来完成任务和业务职能。教材例子：云服务提供商和公司构成组织供应链的一部分。

NIST SP 800-39 指出，这种信任关系可以是：

- 在合同、服务级别协议、工作说明、协议/谅解备忘录或互连安全协议中正式记录的；
- 可扩展的、组织间的或组织内的；
- 两个伙伴之间的简单双边关系，或许多伙伴之间更复杂的多对多关系。

建立和维护信任取决于：

- 任务/业务要求；
- 信任关系涉及的参与者；
- 共享信息的关键性/敏感性或提供的服务类型；
- 组织之间的历史记录；
- 参与组织的总体风险。

6.3.3 信息系统的可信度

SP 800-39 将信息系统的可信度定义为：期望信息系统在多大程度上保持所处理、存储或传输的信息在各种威胁情况下的保密性、完整性和可用性。

影响信息系统可信度的两个因素：

因素	教材说明
安全功能	系统内使用的安全特性/功能，包括本书讨论的密码和网络安全技术
安全保证	对安全功能在应用中发生效用有信心的理由；通过安全管理技术保证，如审核并将安全考虑纳入系统开发生命周期

6.4 建立信任关系的方法

SP 800-39 描述了组织建立信任关系的方法：

方法	教材核心含义
验证的信任	基于信任组织获得的有关受信任组织或实体的证据，如信息安全策略、安全措施、监督级别、安全计划、评估结果
直接历史信任	基于组织展示的与安全相关的历史记录，特别是与寻求建立信任的组织交互过程中的历史记录
中介信任	使用由两方相互信任的第三方，由第三方为前两方之间的给定信任水平提供保证；例子是公钥证书颁发机构
强制信任	根据第三方在权威地位的特定授权下建立与另一组织的信任级别

组织可能组合使用这些方法，与许多其他实体建立关系。

7. 学习目标 6：与密码标准相关的组织

教材 1.9 说明：许多安全技术和应用程序已成为标准，已颁布的标准还覆盖管理实践、安全机制和服务的总体架构。本书描述密码学和网络安全方面正在使用或开发的重要标准。

组织	教材描述	复习关键词
NIST 美国国家标准与技术研究院	美国联邦机构，致力于与美国政府使用和促进美国私营部门创新有关的测量科学、标准与技术；FIPS 和 SP 具有全球影响力	FIPS、SP、全球影响力
ISOC 因特网协会	具有全球组织和个人会员资格的专业会员协会，在解决未来因特网问题方面发挥领导作用；是 IETF 和 IAB 等因特网基础设施标准小组的组织机构	IETF、IAB、RFC
ITU-T 国际电信联盟电信标准化部门	ITU 是联合国系统内协调全球电信网络和服务的国际组织；ITU-T 是 ITU 三个部门之一，任务是制定涵盖所有电信领域的技术标准	建议书、X.800
ISO 国际标准化组织	由全球 140 多个国家的国家标准机构组成的全球联盟，每个国家一个；非政府组织，促进标准化和相关活动发展，促进商品和服务国际交流	国际标准、非政府组织

补充记忆：教材脚注说明 ISO 不是缩写；若为缩写应写成 IOS。ISO 源自希腊语，意思是“等于”。

8. 本章关键术语整理

类别	术语
安全目标	保密性、数据保密性、隐私、完整性、数据完整性、系统完整性、可用性、真实性、可审计性、不可否认性
OSI 安全架构	安全攻击、安全服务、安全机制、威胁、攻击、X.800
攻击类型	被动攻击、主动攻击、窃听、伪装、重放、消息篡改、拒绝服务、中间人攻击
安全服务	认证、对等实体认证、数据源认证、访问控制、数据保密性、数据完整性、不可否认性、可用性服务
安全机制	密码算法、数据完整性、数字签名、认证交换、流量填充、路由控制、公证、访问控制
密码学	无密钥算法、单密钥算法、双密钥算法、对称加密算法、非对称加密算法、分组密码、流密码、加密哈希函数、伪随机数生成器、消息认证码、数字签名算法、密钥交换
网络安全	通信安全、设备安全、防火墙、入侵检测、入侵防御、IPsec、IEEE 802.11i、TLS、SSH
信任	信任、可信度、信任倾向、风险、能力、善意、完整性、信任关系、验证的信任、直接历史信任、中介信任、强制信任
标准组织	NIST、FIPS、SP、ISOC、IETF、IAB、RFC、ITU-T、ISO

9. 学习目标自检

1. 能否不用例子直接说清保密性、完整性、可用性的定义和缺失后果？
2. 能否区分威胁、攻击、安全服务、安全机制？
3. 能否说明被动攻击为什么重在预防，主动攻击为什么重在检测和恢复？
4. 能否列出主动攻击四类：伪装、重放、消息篡改、拒绝服务？
5. 能否说明认证、访问控制、数据保密性、数据完整性、不可否认性、可用性服务分别解决什么问题？
6. 能否概述无密钥、单密钥、双密钥算法，并举出哈希函数、分组密码/流密码、数字签名或密钥交换等对应内容？

7. 能否说明网络安全包含通信安全和设备安全，并列出 IPsec、IEEE 802.11i、TLS、SSH、防火墙、入侵检测、入侵防御？
8. 能否描述信任模型中的可信度、信任倾向、风险，以及能力、善意、完整性三个可信度因素？
9. 能否列出 NIST、ISOC、ITU-T、ISO，并说明各自与标准的关系？